



Rapport d'avancement

Intégration de l'IA générative et de la blockchain pour la lutte automatisée contre le phishing et les fraudes Web3

BINÔME

Lamkhaifi Mohamed
Malek Mouhcine

ÉTAT CONSOLIDÉ AU

11 août 2026
Version 1.0

01

Synthèse exécutive

Position réelle du prototype au 11 août 2026, distinguant clairement réalisation, intégration et validation.

Le projet vise à transformer un signalement d'URL ou de wallet suspect en une décision explicable, puis — uniquement lorsque le niveau de risque est suffisant — en une inscription vérifiable sur une blockchain de test et une alerte communautaire. L'approche retenue combine trois qualités complémentaires : la capacité d'analyse de l'IA générative, l'automatisation de n8n et la traçabilité d'un registre on-chain.

131

tests automatisés passants

118 Node + 13 Hardhat

100 %

couverture des lignes du smart contract

100 %

précision IA v1 sur 32 cas mesurables

46,2 %

rappel IA v1

objectif contractuel : ≥ 80 %

Ce qui est solidement établi

Socle blockchain et sécurité

✓

PhishingRegistry déployé et vérifié sur Polygon Amoy.

✓

Rôles Owner/Reporter, blacklist URL/wallet, suppression contrôlée et events.

✓

Scripts d'interaction, bridge HTTP interne, persistance SQLite et retries testés.

✓

Audit Slither sans finding critique, haut, moyen ou faible.

Socle IA et données

✓

Prompts spécialisés URL, structure et sémantique, avec sortie JSON stricte.

✓

Gemini principal, NVIDIA NIM en fallback sur incidents transitoires.

✓

Dataset documenté et capture isolée sans exécution JavaScript.

✓

Évaluation v1 honnête ayant localisé un défaut de rappel précis.

Position d'avancement globale

Ensemble	État vérifié	Lecture de l'état
Contrat, scripts et déploiement Amoy	● Réalisé	Fonctionnels et vérifiés séparément, avec transactions de démonstration.
Module IA v1	● Partiel	Architecture réalisée et précision forte, mais rappel inférieur à la cible.
WF3 Action et WF4 Check	● Implémentés, inactifs	Exports et logique testés hors ligne ; credentials et activation contrôlée restent à faire.
WF1 Ingestion et WF2 Analyse	● À intégrer	Le chaînage d'entrée, le fetch sécurisé et l'appel IA ne sont pas présents comme workflows actifs.
Démo bout-en-bout	● Non validée	Aucune preuve ne permet encore de déclarer le flux complet opérationnel.

Conclusion de gestion. Le prototype possède un socle technique avancé, surtout sur la publication blockchain, la fiabilité et les contrôles de sécurité. Il n'est cependant pas encore un produit intégré : les priorités sont l'amélioration du rappel IA, l'implémentation de WF1-WF2 et un test E2E contrôlé reliant IA, Polygon Amoy, Discord et l'endpoint de vérification.

02 Sommaire & conventions

Une lecture progressive : du sujet initial aux preuves, limites et travaux restants.

01	Synthèse exécutive	2	10	Scripts et chain bridge	11
02	Sommaire et conventions	3	11	Module IA : conception v1	12
03	Contexte et problématique	4	12	Dataset et capture sécurisée	13
04	Objectifs et critères de succès	5	13	Résultats IA v1	14
05	Démarche adoptée	6	14	Plan d'amélioration Recall v2	15
06	Architecture globale	7	15	Orchestration n8n	16
07	Contrats intermodules et décision	8	16	Sécurité et modèle de menace	17
08	Smart contract PhishingRegistry	9	17	Tests, couverture, CI et audit	18
09	Déploiement et preuves on-chain	10	18	Bilan, difficultés et enseignements	19
19	Feuille de route et conclusion	20			

Conventions de statut utilisées dans ce rapport

● Réalisé

Code et preuves présents ; comportement vérifié par tests, artefacts, transaction publique ou audit approprié.

● Implémenté / partiel

Composant développé, mais dépendance, activation, performance cible ou validation réelle encore manquante.

● À faire / non validé

Élément absent du dépôt actif ou résultat non démontré. Il n'est jamais présenté comme opérationnel.

● Objectif initial

Exigence du cahier des charges. Un objectif n'est pas une preuve d'achèvement ; son état est évalué séparément.

Périmètre rédactionnel. Le document présente le travail du binôme comme une réalisation collective. Il s'appuie sur l'état du dépôt, les rapports générés, les exports de workflows, les tests exécutés et les preuves publiques disponibles. Les éléments projetés sont explicitement signalés comme tels.

Référentiel temporel

Le plan initial couvre 40 jours ouvrés et les documents techniques de suivi décrivent un état au 3 août 2026. Les suites de tests ont été rejouées pour ce rapport le 11 août 2026 sur la branche main, commit 2e99059. L'absence de modification fonctionnelle ultérieure prouvée conduit à conserver les statuts d'intégration documentés : WF3/WF4 inactifs, WF1/WF2 à intégrer et E2E non déclaré.

03

Comprendre le sujet initial

Pourquoi rapprocher analyse cognitive, orchestration et registre blockchain dans un même prototype ?

Dans l'écosystème Web3, le phishing ne vise pas seulement des identifiants classiques. Il peut détourner une signature, imiter une plateforme d'échange, se présenter comme un support officiel, proposer un faux airdrop ou conduire l'utilisateur vers un wallet drainer. La vitesse de création et de disparition de ces campagnes rend difficile une réponse exclusivement manuelle.

Problème directeur : comment détecter, qualifier et partager une menace Web3 en quasi-temps réel, de façon automatisée, traçable et consultable par la communauté ?

Limites d'une réponse traditionnelle

Temps de réaction

Une collecte et une validation manuelles peuvent arriver après la disparition ou la migration du domaine frauduleux.

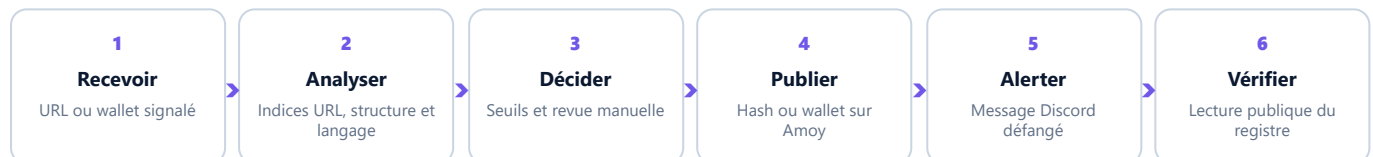
Confiance dans le verdict

Un score automatisé sans explication ni historique est difficile à auditer, contester et réutiliser.

Partage fragmenté

Un signalement isolé protège peu si son résultat reste enfermé dans un outil ou une base centralisée.

Réponse proposée par le projet



Périmètre fonctionnel retenu

- ✓ Signalement d'URLs HTTP(S) et d'adresses EVM.
- ✓ Analyse par Gemini avec fallback NVIDIA NIM.
- ✓ Catégories Web3 fermées : faux exchange, drainer, faux airdrop, faux support, Ponzi, autre.
- ✓ Blacklist sur Polygon Amoy, testnet sans fonds réels.
- ✓ Alertes Discord et endpoint de vérification.
- ✓ Contrôles de sécurité sur clés, entrées, contenu hostile et infrastructure.

Hors périmètre

- Déploiement mainnet et manipulation de fonds réels.
- Exécution dynamique du JavaScript d'un site hostile.
- Extension navigateur complète.
- Analyse de SMS ou d'e-mails bruts.
- Garantie qu'un verdict automatisé constitue une vérité juridique.

Acteurs et responsabilités du système

Acteur	Rôle	Contrainte de confiance
Signaleur	Soumet une cible et un contexte éventuel.	Entrée considérée non fiable, strictement validée.
n8n	Orchestre les étapes et conserve le cycle de vie.	Ne reçoit jamais la clé Owner et n'exécute pas de shell utilisateur.
Reporter on-chain	Publie les entrées validées.	Privilege limité, révocable par l'Owner.
Owner	Administre les reporters et corrige un faux positif.	Clé conservée hors de n8n et du bridge.
Consommateur	Consulte gratuitement le statut public.	Reçoit une réponse filtrée, sans détails internes inutiles.

04

Objectifs traduits en preuves

Chaque ambition du cahier des charges est associée à un critère mesurable et à un état constaté.

L'objectif général est de construire un prototype capable de recevoir un signalement, d'en qualifier le risque, de publier les menaces retenues sur un registre public et d'en diffuser l'information. Pour éviter une lecture binaire « fait / non fait », l'évaluation ci-dessous distingue la brique technique, son niveau d'intégration et la preuve disponible.

ID	Objectif initial	Critère de succès	État au 11/08	Preuve / écart
O1	Capturer des signalements multi-sources	Webhook + formulaire, réponse < 2 s	● À intégrer	WF1 n'est pas présent comme workflow opérationnel.
O2	Qualifier automatiquement la fraude	Précision ≥ 85 %, rappel ≥ 80 %	● Partiel	Précision 100 %, rappel 46,2 % sur le run v1.
O3	Publier la blacklist on-chain	Contrat vérifié, écriture < 30 s après verdict	● Socle réalisé	Contrat et publication isolée prouvés ; délai depuis un verdict E2E non mesuré.
O4	Alerter la communauté	Discord < 10 s après verdict	● Implémenté	Payload, claims et workflow testés hors ligne ; envoi live non validé.
O5	Permettre la vérification par tous	Endpoint public URL/wallet	● Implémenté	WF4 exporté inactif ; lecture chaîne et filtrage testés.
O6	Sécuriser l'infrastructure	0 vulnérabilité critique, aucun secret en clair	● Atteint sur le socle	Audit Slither propre, séparation Owner/Reporter et bridge durci.

Principes d'acceptation adoptés

Une preuve doit être adaptée à l'affirmation

- Un test unitaire prouve une règle locale, pas une intégration live.
- Une transaction Amoy prouve une écriture réelle, pas l'origine IA du verdict.
- Un export n8n prouve l'existence du graphe, pas son activation.
- Un rapport d'évaluation prouve un run donné, pas une performance générale.

Une action irréversible exige plus de certitude

- Seul malicious avec score final ≥ 0,80 peut publier.
- Les cas ambigus sont orientés vers la revue manuelle.
- Un résultat blockchain incertain est relu avant tout retry.
- Les faux positifs peuvent être désactivés uniquement par l'Owner.

Indicateurs actuellement disponibles

1

contrat public déployé et vérifié

2

workflows exportés et volontairement inactifs

296

entrées du jeu final
36 phishing + 260 légitimes

0

finding Slither critique, haut, moyen ou faible

Indicateurs encore absents. La latence complète, le taux de succès du pipeline, le délai Discord, le comportement sous charge et le nombre de transactions issues d'un verdict IA ne pourront être mesurés honnêtement qu'après connexion de WF1 et WF2, activation contrôlée de WF3/WF4 et exécution d'un scénario E2E instrumenté.

05

Démarche adoptée

Découper les risques, figer les interfaces, sécuriser les effets externes et documenter les écarts.

Le sujet a été abordé comme un système distribué composé de sous-ensembles testables indépendamment. Ce choix permet d'avancer en parallèle sans attendre l'intégration complète, tout en réduisant le risque qu'un contenu hostile, une réponse LLM imprévisible ou une erreur RPC déclenche une action non maîtrisée.



Phase 0 - Cadrage et environnement

Définition du périmètre, des acteurs, du mono-repo, du testnet, des catégories et des règles de gestion des secrets.



Phase 1 - Registre blockchain

Conception du modèle de données, contrôle d'accès, tests Hardhat, déploiement et vérification publique sur Polygon Amoy.



Phase 2 - Analyse IA et données

Prompts spécialisés, client multi-provider, schéma JSON fermé, dataset traçable, capture isolée et première évaluation.



Phase 3 - Orchestration

Bridge interne, logique WF3/WF4, machine à états, retries, idempotence, construction sûre des alertes et exports n8n.



Phases 4-5 - Sécurisation et intégration

Audit, durcissement des conteneurs, CI et préparation des travaux E2E encore nécessaires.

Six choix méthodologiques structurants

1. Interfaces figées avant intégration

Les formats de signalement, de verdict IA, de catégories, de score, de réponse publique et les fonctions Solidity servent de contrats entre composants.

2. Testnet et données de démonstration sûres

Polygon Amoy évite tout fonds réel. Les démonstrations utilisent des domaines `.invalid`, non résolubles par conception.

3. Séparation analyse / décision / action

Le LLM propose un verdict structuré, mais ne possède aucune clé et ne déclenche jamais directement une transaction.

4. Validation fermée aux frontières

Les schémas refusent les champs inconnus ; URL, wallet, catégorie, score et identifiants sont normalisés ou rejetés.

5. Mesure reproductible plutôt que favorable

Le dataset final est séparé du développement, le cache est indexé et la faiblesse du rappel v1 est conservée au lieu d'être masquée.

6. Effets externes réconciliables

Après un timeout blockchain, l'état on-chain est relu. Avant Discord, un claim persistant unique est obtenu par compare-and-swap.

Organisation collective

Le travail est présenté comme une production de binôme. La complémentarité des compétences a permis de développer plusieurs briques en parallèle, tandis que les interfaces partagées, les revues croisées et les tests automatisés ont servi de mécanisme de coordination. Cette organisation évite de réduire le projet à deux silos : les catégories IA correspondent à l'enum blockchain, le score devient un entier on-chain et la réponse publique n'expose que les données nécessaires.

Résultat méthodologique important. Même si l'intégration finale n'est pas terminée, les composants les plus sensibles — écriture on-chain, gestion des rôles, erreurs transitoires, concurrence, format Discord et validation des entrées — disposent déjà de comportements explicites et testés. Le travail restant est donc identifiable et séquencé, plutôt qu'indéterminé.

06

Architecture cible et état d'intégration

Les zones de confiance et les dépendances sont visibles avant toute activation du pipeline.



Flux cible détaillé

Étape	Traitement	Frontière de sécurité	État
1 - Ingestion	Recevoir, valider, normaliser le type, générer un reportId.	Corps borné, champs inconnus rejetés, rate limiting.	WF1 absent
2 - Déduplication	Interroger le registre avant tout appel IA.	Lecture seule ; aucune clé privée nécessaire.	Bridge prêt
3 - Capture	Récupérer du HTML sans JavaScript, extraire texte et structure.	Protection SSRF, DNS contrôlé, timeout et taille maximale.	Outil dataset
4 - IA	Analyser URL, structure et sémantique ; valider le JSON.	Prompt injection neutralisée ; retries bornés.	v1 à améliorer
5 - Décision	Appliquer verdict, score et seuils ; choisir report, revue ou log.	Aucun verdict non malveillant ne peut publier.	Logique testée
6 - Publication	Écrire via Reporter, attendre confirmation et tx hash.	Owner absent ; recheck après résultat incertain.	WF3 inactif
7 - Alerte	Défanger la cible, limiter les indicateurs, router Discord.	Claim persistant unique, mentions désactivées.	Live à valider
8 - Vérification	Répondre publiquement à GET /check.	Masquer hash, reporter et détails internes.	WF4 inactif

Pourquoi une blockchain de test ?

Polygon Amoy fournit un environnement EVM compatible, public et vérifiable, sans exposer de fonds réels. Il permet de démontrer les propriétés recherchées : droits d'écriture restreints, lecture publique, historique d'événements et preuve de transaction. La blockchain n'effectue pas l'analyse : elle conserve le résultat retenu et son contexte minimal.

Limite assumée

Une inscription on-chain n'est pas automatiquement vraie parce qu'elle est immuable. La confiance dépend aussi de la qualité de l'analyse, de la gouvernance des reporters et du mécanisme de correction.

Technologies retenues

Solidity 0.8.24

Hardhat 2.29

ethers.js 6.16

Node 22.14

n8n 2.32.7

Docker Compose

Gemini API

NVIDIA NIM

SQLite

07

Du verdict IA à l'action contrôlée

Des contrats de données stricts empêchent qu'un texte libre ou une catégorie incohérente atteigne la blockchain.

Sortie IA canonique

```
{ "verdict": "malicious", "confidence": 0.94, "category":
  "wallet_drainer", "indicators": [ "Demande de seed phrase",
    "Domaine
    imitant une marque" ], "explanation": "Explication courte et
    vérifiable." }
```

Contraintes essentielles

- ✓ Objet JSON fermé, sans propriété additionnelle.
- ✓ Confiance bornée entre 0 et 1.
- ✓ Maximum cinq indicateurs, chacun ≤ 200 caractères.
- ✓ Explication ≤ 500 caractères.
- ✓ Catégorie non nulle uniquement pour malicious.

Catégories alignées sur le contrat

Valeur IA / n8n	Enum Solidity	Interprétation
fake_exchange	0 · FakeExchange	Imitation de plateforme d'échange.
wallet_drainer	1 · WalletDrainer	Signature ou autorisation destinée à vider un wallet.
fake_airdrop	2 · FakeAirdrop	Récompense ou claim trompeur.
fake_support	3 · FakeSupport	Usurpation de support client ou d'administrateur.
ponzi	4 · Ponzi	Promesse de rendement frauduleuse.
other	5 · Other	Menace confirmée ne relevant pas des classes précédentes.

Règle de décision WF3

● Publication

malicious et score ≥ 0,80

Conversion en entier 0-100, appel du bridge, confirmation du tx hash, puis alerte.

● Revue manuelle

suspicious ou zone 0,50-0,79

Aucune transaction. Un message séparé expose les éléments disponibles sans prétendre à une publication.

● Journalisation

legitimate ou score < 0,50

Conservation du résultat uniquement ; la branche blockchain est inaccessible.

Formule prévue. Le cahier des charges définit un score final combinant 70 % de risque LLM et 30 % de features URL. Le correctif v2 doit distinguer la confiance dans un verdict de la probabilité de phishing : pour un verdict légitime de confiance 0,98, le risque LLM est 0,02 et non 0,98. La publication reste conditionnée à `verdict === "malicious"` en plus du seuil.

Normalisation des URLs avant hachage



`HTTPS://www.Blnance-Support.xyz/claim/?ref=x#top` devient `blnance-support.xyz/claim`. Des variantes équivalentes retrouvent ainsi la même entrée sans publier l'URL en clair dans le registre.

Transparence. Le score URL complet décrit dans le plan Recall v2 n'est pas encore implémenté dans l'état audité. La règle de décision WF3 est testée, mais elle attend de WF2 un `scoreFinal` déjà calculé et validé.

08

Le registre PhishingRegistry

Une blacklist permissionnée en écriture, publique en lecture et conçue sans transfert de fonds.

Le contrat Solidity constitue le registre partagé du prototype. Il ne décide pas qu'une cible est malveillante : il reçoit une décision déjà contrôlée, l'associe à des métadonnées minimales et rend son statut consultable par toute application compatible EVM.

Modèle de données

```
enum Category { FakeExchange, WalletDrainer, FakeAirdrop,
FakeSupport,
Ponzi, Other } struct Entry { Category category; uint8 score; // 0
à 100
uint40 timestamp; address reporter; bool active; }
```

Deux espaces de clés

URLs

Stockées sous forme de bytes32, obtenu par keccak256 d'une URL normalisée hors chaîne.

Wallets EVM

Stockés directement comme address, après validation et checksum dans les scripts.

Surface fonctionnelle

Famille	Fonctions	Autorisation	Comportement
Administration	setReporter	Owner	Autorise ou révoque une adresse de publication non nulle.
Publication	reportURL, reportWallet	Reporter	Valide le score et refuse une entrée déjà active.
Lecture	isBlacklisted*, get*Entry	Publique	Retourne le statut actif et les métadonnées sans transaction.
Correction	removeURL, removeWallet	Owner	Désactive l'entrée ; les logs de transactions restent historiques.

Événements et auditabilité

URLReported

hash, catégorie, score, reporter

WalletReported

wallet, catégorie, score, reporter

EntryRemoved

clé et nature URL/wallet

ReporterUpdated

adresse et autorisation

Propriétés de sécurité obtenues

- ✓ **Contrôle d'accès** : OpenZeppelin Ownable pour l'administration et modifier dédié pour la publication.
- ✓ **Validation** : wallet et reporter nuls refusés, score borné, doublon actif rejeté.
- ✓ **Complexité bornée** : mappings et absence de boucle non bornée ; écritures en temps constant.
- ✓ **Absence de réentrance pratique** : aucun transfert de fonds ni appel externe.
- ✓ **Correction gouvernée** : seul l'Owner désactive une entrée en cas de faux positif.
- ✓ **Historique** : la désactivation modifie l'état actif mais n'efface pas les events déjà inscrits.

Limite de conception. Le registre est décentralisé dans sa consultation et sa traçabilité, mais l'écriture reste permissionnée. Cette décision réduit le spam et les publications arbitraires pour le prototype ; une version communautaire nécessiterait réputation, staking, contestation ou gouvernance multi-acteurs.

09

Du contrat local à Polygon Amoy

Les preuves publiques démontrent le déploiement, une publication réelle et le cycle de correction d'un faux positif.

80002

Chain ID

Polygon Amoy

43 090 902

bloc de déploiement configuré

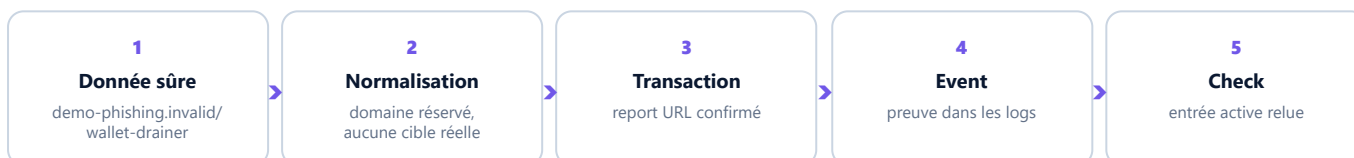
6

catégories de fraude supportées on-chain

Identité du déploiement

Contrat	PhishingRegistry · Solidity 0.8.24 · OpenZeppelin Ownable
Adresse	0x8d51dB4a92c338075360A17AcA005ec282fe1f23
Déploiement	0x8e2e4e3c73ca2a7a5dd1f35372945c8462c8b6c194db6b36ccc2e93dc46de2dc
Vérification	Code source publiquement vérifié dans l'explorateur Amoy PolygonScan.

Preuve 1 · cycle de publication blockchain

**TX****Transaction de démonstration**

0x208b9ccdfef10daf464321e571b341b280694c4bfc364d590267794c50a33943

Cette preuve valide la chaîne **report** → **event** → **check** au niveau blockchain. Elle n'établit pas que le signalement provenait de WF1/WF2 ou que Discord a été appelé.

Preuve 2 · correction d'un faux positif

R**Signalement de test**

0xde03a89b...dae1d4b459

X**Désactivation par l'Owner**

0x55cad45e...303ade17c

La cible false-positive.invalid/remove-me a été publiée puis désactivée. La lecture active devient fausse, tandis que les événements restent visibles. Cela démontre la procédure d'administration sans exposer une URL malveillante réelle.

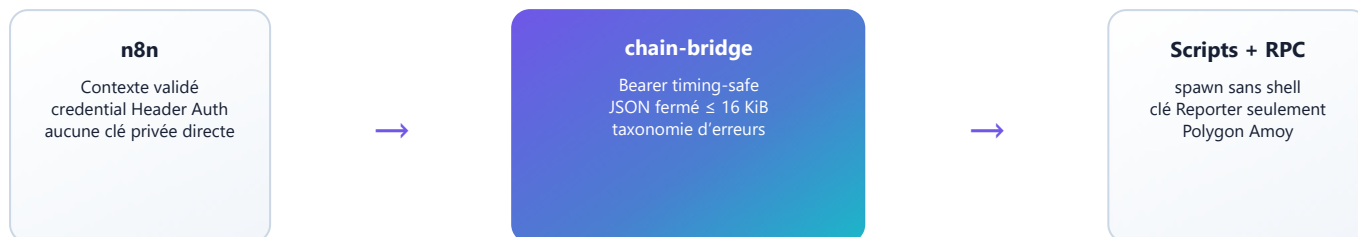
Scripts d'exploitation livrés

Script	Rôle	Clé requise	Sortie
check.js	Lecture URL/wallet et recherche du dernier tx hash.	Aucune	JSON interne complet ou public filtrable.
report.js	Publication, confirmation et réconciliation d'incertitude.	Reporter	reported ou already_blacklisted.
remove.js	Désactivation administrative d'un faux positif.	Owner	Tx hash ou not_blacklisted.
batchReport.js	Publication séquentielle depuis un fichier contrôlé.	Reporter	Résultats JSON par entrée.
listen.js	Lecture historique ou suivi continu des events.	Aucune	Flux d'événements normalisés.

10

Une frontière de confiance explicite

n8n ne reçoit ni scripts hôte ni clé Owner : toutes les opérations blockchain passent par un service interne borné.



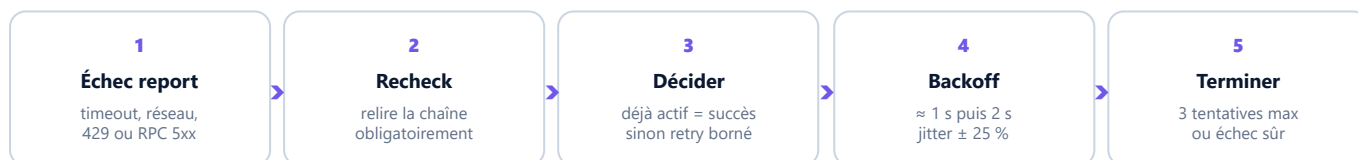
Contrôles à l'entrée du bridge

- ✓ Token bearer d'au moins 32 caractères, comparé avec `timingSafeEqual`.
- ✓ Content-Type: `application/json` obligatoire et corps limité à 16 KiB.
- ✓ Objet exact : champs manquants ou inattendus rejetés.
- ✓ URL, wallet, catégorie et score validés par une liste fermée.
- ✓ Processus enfant lancé avec arguments séparés et `shell: false`.
- ✓ Sortie limitée et validée comme un unique objet JSON.
- ✓ Erreurs RPC brutes remplacées par des codes techniques sûrs.
- ✓ Endpoint santé minimal : `{ "status": "ok" }`.

Routes internes implémentées

Route	Finalité	Effet externe possible
POST <code>/internal/check</code>	Lecture et normalisation d'une cible.	Aucun.
POST <code>/internal/report</code>	Publication d'une cible validée.	Transaction Reporter.
<code>/internal/lifecycle/{create,read,cas}</code>	Gestion atomique du cycle de vie.	Écriture SQLite uniquement.
<code>/internal/wf3/{execute,claim,settle}</code>	Coordination publication, alerte et reprise.	Transaction puis autorisation Discord.

Fiabilité face aux erreurs transitoires



Idempotence et concurrence

Chaque `reportId` est lié à une empreinte SHA-256 du contexte et, pendant un effet ouvert, à un `executionId`. SQLite conserve un numéro de révision. Les transitions et claims sont appliqués par compare-and-swap : une seule exécution peut gagner le droit d'envoyer l'alerte finale.

Une réutilisation du même identifiant avec une cible ou un verdict différent est un conflit, pas un nouveau traitement. Un replay terminal retourne l'état persisté sans répéter la transaction.

Limite « exactly once »

Discord ne fournit pas de clé d'idempotence. Une panne entre la réception du message et l'enregistrement local empêche de savoir avec certitude si l'envoi a réussi.

Le choix retenu privilégie l'absence de doublon : l'état devient incertain et aucun renvoi automatique n'est effectué.

Apport au projet. Cette architecture empêche qu'une URL contrôlée par un utilisateur soit interpolée dans une commande et limite la clé Reporter au seul service qui en a besoin. Elle transforme une orchestration visuelle en chaîne d'effets persistante, testable et auditable.

11 Conception du module IA v1

Un appel combiné examine la structure de l'URL, le contenu visible et un digest structural borné.

Le module IA ne reçoit jamais un site comme une source d'instructions. Il reçoit des représentations textuelles explicitement délimitées et doit retourner uniquement un objet JSON validable. L'architecture cherche à conjuguer capacité d'interprétation et comportement fermé en cas d'erreur.

1 · Analyse d'URL

- Typosquatting et distance avec une marque connue.
- Homoglyphes, substitutions et punycode.
- TLD, sous-domaines trompeurs et raccourcisseurs.

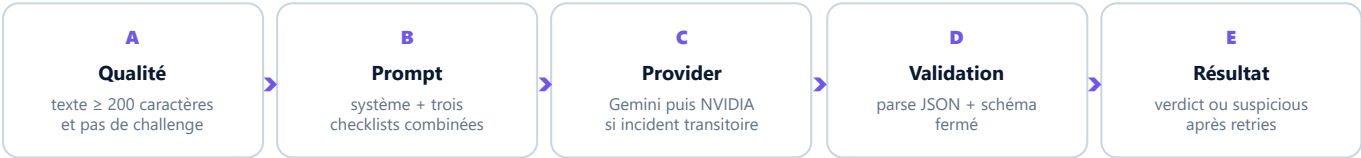
2 · Analyse structurelle

- Champs demandant seed phrase ou clé privée.
- Motifs eth_sign, approve, setApprovalForAll.
- Domaines de scripts externes et indices de clonage.

3 · Analyse sémantique

- Urgence artificielle et menace de blocage.
- Faux support ou vérification externe.
- Faux airdrop et rendement irréaliste.

Chaîne de traitement d'une analyse v1



Stratégie multi-provider

Situation Gemini	Comportement	Justification
Réponse valide	Conserver le verdict Gemini.	Chemin nominal et latence minimale.
Timeout, HTTP 429 ou 5xx	Basculer vers NVIDIA NIM.	Incident supposé transitoire, continuité de service.
Erreur définitive, ex. configuration invalide	Ne pas masquer par un fallback.	Une mauvaise configuration doit être corrigée explicitement.
JSON invalide ou schéma refusé	Réessayer jusqu'à deux fois, puis suspicious.	Aucune sortie libre ne doit franchir la frontière IA.

Défense contre la prompt injection

Le message système déclare que tout ce qui se trouve entre <<<URL>>>, <<<PAGE_TEXT>>> et <<<STRUCTURAL_DIGEST>>> est une donnée non fiable. Une phrase comme « ignore les consignes précédentes » doit devenir un indicateur de manipulation, jamais une instruction.

Le modèle ne reçoit pas le HTML/JavaScript brut et ne dispose d'aucun outil. Les extraits sont bornés, les indicateurs sont limités à cinq et la réponse est fermée par le schéma.

Métadonnées techniques retournées

manualReview
modelUsed et modelName
latencyMs
retries
reason pour les fallbacks sûrs

Défaut identifié de la v1. Lorsque le texte contient moins de 200 caractères ou ressemble à une page de challenge, le client court-circuite toute analyse et retourne immédiatement suspicious. Cette règle prudente évite les faux positifs, mais elle produit sept faux négatifs dans l'évaluation stricte. Le plan v2 détaillé en page 15 corrige ce point sans assouplir la définition des métriques.

12

Données traçables et capture isolée

Le jeu final sépare développement, mesure officielle et cas historiques, sans refetch pendant l'évaluation.

36

URLs phishing dans le jeu
final

260

URLs légitimes dans le jeu
final

10

cas historiques documentés,
hors mesure

12,2 %

part de phishing dans le jeu
final déséquilibré

Trois périmètres distincts

Jeu	Usage	Nature	Règle d'évaluation
dev/	Itération sur prompts et client.	Cas synthétiques sur domaines .invalid, contenu inclus.	Jamais utilisé comme résultat final.
final/	Mesure précision, rappel et F1.	36 phishing sourcés + 260 sites Web3 légitimes.	Cache figé, intégrité vérifiée, aucun refetch.
historical.json	Illustration de patterns anciens.	10 menaces issues d'une source vieillissante, majoritairement mortes.	Exclu de la mesure officielle.

Pipeline de capture



Le **textExcerpt** alimente l'analyse sémantique. Le **structuralDigest** conserve des métadonnées de formulaires, domaines de scripts et courts extraits autour de motifs Web3 que le texte visible ne révèle pas. Le cache brut reste hors Git car il contient du contenu hostile ; son index versionné permet de vérifier qu'il n'a pas été remplacé ou modifié.

Résultat de la capture du 31 juillet 2026

Jeu	n	ok	dead	empty	challenged	refused	skipped	Taux ok
Phishing	36	11	10	10	0	5	0	30,6 %
Légitime	260	187	10	45	1	16	1	71,9 %
Historique	10	0	8	2	0	0	0	0 %

Mortalité des menaces

Neuf des dix échecs dead phishing sont des ENOTFOUND : les domaines ne résolvaient déjà plus au moment de la capture. Capturer tôt est donc déterminant.

Longueur du contenu

La médiane du texte phishing capturé est de 285 caractères contre 3 756 pour le légitime, soit environ treize fois moins. Ce signal peut devenir un biais si le modèle apprend « court = phishing ».

Biais et limites explicitement documentés

- Le jeu phishing est dominé par fake_exchange (19/36) ; les métriques par catégorie ne sont pas statistiquement exploitables.
- Les catégories phishing sont souvent déduites du domaine et marquées unverified ; seule la vérité terrain binaire phishing/légitime est utilisée.
- Des pages de login, support, airdrop officiel et wallet-connect légitimes ont été ajoutées pour réduire le confondant « page d'action = phishing ».
- Les timeouts de certains sites légitimes peuvent provenir d'un filtrage réseau ou géographique, mais cette hypothèse n'est pas déclarée comme un fait.

13

Résultats IA v1 : précis mais incomplets

L'évaluation stricte révèle zéro faux positif, mais sept menaces non classées « malicious ».

100 %

précision

6 TP / 0 FP

46,2 %

rappel

6 TP / 7 FN

63,2 %

F1 harmonique

précision / rappel

Protocole du run conservé

Le rapport v1 contient 40 entrées candidates, dont 32 traitées et 8 exclues comme non mesurables (dead: 6, refused: 2). La classification est volontairement stricte : seul verdict === "malicious" compte comme prédiction positive ; suspicious reste une décision de revue manuelle et est donc négative pour le calcul du rappel.

Matrice de confusion

Réalité / prédiction	Malicious	Non malicious
Phishing	TP = 6	FN = 7
Légitime	FP = 0	TN = 19

Formules

$$\text{Précision} = \text{TP} / (\text{TP} + \text{FP})$$
$$\text{Rappel} = \text{TP} / (\text{TP} + \text{FN})$$
$$\text{F1} = 2 \times \text{précision} \times \text{rappel} / (\text{précision} + \text{rappel})$$

Cible : précision ≥ 85 % et rappel ≥ 80 %.

Analyse par chemin d'exécution

Groupe	n	TP	FP	FN	TN	Lecture
Gemini	7	6	0	0	1	100 % précision et rappel sur ce sous-ensemble très réduit.
Aucun modèle	25	0	0	7	18	Le court-circuit déterministe produit tous les faux négatifs.

Cause racine localisée. Les sept faux négatifs ne proviennent pas d'une mauvaise réponse Gemini. Ils appartiennent tous au groupe none : pour un texte trop court ou une page de challenge, `assessContentQuality()` interdit tout appel au modèle et force `suspicious`. La règle protège la précision, mais rend le détecteur aveugle à des indices URL ou structurels encore disponibles.

Ce que les chiffres permettent — et ne permettent pas — de conclure

Conclusions valides

- ✓ Le run n'a produit aucun faux positif parmi 19 cas légitimes mesurés.
- ✓ Le rappel global est inférieur de 33,8 points à la cible de 80 %.
- ✓ Le point de blocage est la politique de contenu, pas le sous-ensemble Gemini observé.

Conclusions interdites

- Ne pas généraliser « Gemini = 100 % » à partir de sept cas.
- Ne pas présenter la cible IA comme atteinte.
- Ne pas compter `suspicious` comme malveillant pour améliorer artificiellement le rappel.

Reproductibilité à renforcer. Le rapport v1 ne consigne pas encore explicitement le commit, le hash de l'index, la date, la commande exacte, le modèle et les versions de prompts. Le prochain run doit enregistrer ces éléments sans modifier ni écraser le rapport v1.

14

Améliorer le rappel sans tricher

Le seuil de 200 caractères doit sélectionner un mode d'analyse, et non imposer à lui seul le verdict.

Statut. La spécification Recall v2 est documentée mais n'est pas encore implémentée dans l'état audité. Cette page décrit le travail planifié, pas un résultat acquis.

Trois modes fondés sur les preuves disponibles

Mode 1

combined

Texte exploitable : URL, features déterministes, extrait textuel et digest structurel alimentent le même cadre de validation.

Mode 2

url_structural

Texte court mais structure utile : champs de formulaire, scripts externes et motifs Web3 restent analysables.

Mode 3

url_only

Contenu absent, vide ou challenge : analyser l'URL et ses features, sans considérer l'absence comme preuve.

Features URL déterministes prévues

```
scoreURL = 0,30 × scoreTLD + 0,25 × scoreAgeDomaine + 0,20 × scoreHomoglyphe  
+ 0,15 × scoreSousDomaines + 0,10 × scoreRaccourcisseur
```

- ✓ Parser standard URL et Public Suffix List pour le domaine enregistrable.
- ✓ Liste fermée de TLD suspects et de raccourcisseurs.
- ✓ Âge RDAP figé dans le cache ; aucune requête réseau pendant l'évaluation.
- ✓ Détection punycode et table documentée de confusions visuelles.
- ✓ Nombre de sous-domaines calculé avant le domaine enregistrable, jamais depuis le path.
- ✓ Valeur neutre 0,5 lorsque l'âge du domaine est indisponible.
- ✓ Une seule feature ne suffit pas automatiquement à déclarer malicious.
- ✓ Aucune URL du jeu final codée en dur dans la logique.

Corriger la sémantique de confiance

Le champ confiance mesure la confiance dans le verdict retourné, et non le risque de phishing. La transformation prévue est donc :

Verdict	Risque LLM utilisé	Exemple
malicious	confiance	malicious 0,90 → risque 0,90
legitimate	1 - confiance	legitimate 0,98 → risque 0,02
suspicious	0,50	Cas ambigu → risque neutre, revue manuelle

Le score final devient $0,7 \times \text{risque LLM} + 0,3 \times \text{score URL}$. Une feature forte ne peut toutefois pas convertir silencieusement un verdict légitime ou suspect en transaction : le garde-fou verdict == "malicious" demeure.

Plan de validation v2

Tests à ajouter

- Sélection des trois modes et métadonnées associées.
- URL invalide, IP littérale, co.uk, punycode et domaines hébergés.
- Aucune fuite de label, source ou catégorie attendue dans le prompt.
- Fallback, retries et validation identiques pour chaque mode.

Comparaison honnête

- Conserver le cache et le rapport v1 inchangés.
- Rejouer le même périmètre et documenter tous les paramètres.
- Séparer « contenu exploitable » et « disponibilité réaliste ».
- Exiger précision ≥ 85 % et rappel ≥ 80 %, sans relabeling.

15

Workflows livrés et chaînage restant

WF3 et WF4 sont développés, exportés et testés hors ligne, mais volontairement inactifs.

WF1 · Ingestion

● À intégrer

Webhook, formulaire, validation et déduplication.

WF2 · Analyse

● À intégrer

Fetch, features, LLM et score final.

WF3 · Action

● Inactif

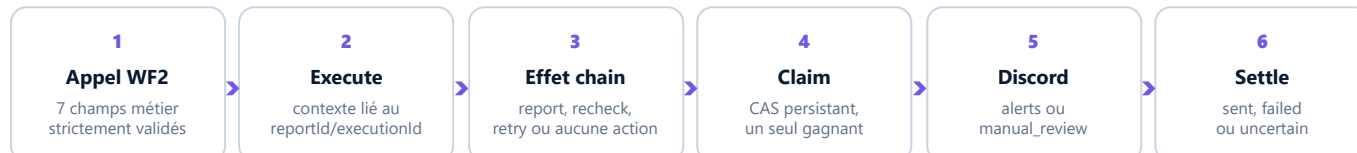
Décision, blockchain, retry, cycle et Discord.

WF4 · Check

● Inactif

GET /check et réponse publique filtrée.

WF3 · chemin d'exécution implémenté



WF4 · réponse publique minimale

```
GET /webhook/check?type=url&value=... { "blacklisted": true, "category": "fake_airdrop", "score": 92, "since": "2026-07-24T16:17:39.000Z", "txHash": "0x..." }
```

Champs internes supprimés

normalizedValue
urlHash
reporter
active
détails RPC ou stack traces

Infrastructure locale

Service	Exposition	Persistance	Protection
n8n 2.32.7	127.0.0.1:5678 uniquement	Volume credentials et workflows	Compte propriétaire natif, clé de chiffrement stable, diagnostics désactivés
chain-bridge	Port 3001 seulement dans le réseau Compose	Volume SQLite dédié	Bearer, non-root, read-only, capacités supprimées, no-new-privileges

Conditions avant activation

- ✓ Configurer localement les credentials Header Auth et les deux webhooks Discord.
- ✓ Vérifier que le bridge est sain et que l'Owner est absent du conteneur.
- ✓ Tester les branches legitimate, suspicious et malicious avec domaines .invalid.
- ✓ Vérifier qu'un replay ne crée ni transaction ni seconde alerte.
- Implémenter WF1, notamment validation, rate limit et déduplication.
- Implémenter WF2, notamment fetch SSRF-safe, mode IA v2 et score final.
- Connecter WF2 à l'entrée exacte de WF3.
- Chronométrer le flux complet et conserver les preuves PolygonScan/Discord.

État déclaré. La présence de deux fichiers JSON n8n ne signifie pas que quatre workflows sont opérationnels. Le dépôt atteste WF3/WF4 en active : false et ne contient pas les exports actifs de WF1/WF2. Le pipeline complet n'est donc pas encore démontré.

16

Sécurité par frontières successives

Le prototype traite comme hostiles les entrées utilisateur, les pages capturées, les réponses LLM et les erreurs de fournisseurs.



Modèle de menace et contrôles réalisés

Menace	Contrôle mis en place	État	Risque résiduel / action
Vol ou abus de la clé d'administration	Owner distinct du Reporter et explicitement absent de n8n/bridge.	● Réalisé	Sécuriser opérationnellement la sauvegarde Owner et prévoir rotation.
Injection de commande via une URL	Schéma fermé, arguments séparés, spawn et shell : false.	● Testé	Conserver l'interdiction d'Execute Command dans n8n.
Requête interne SSRF depuis un site soumis	Capture isolée : protocole, DNS, IP privées/loopback/link-local, redirections et taille contrôlés.	● Outil prêt	Intégrer le même fetch sécurisé dans WF2 et exécuter les tests d'attaque.
Prompt injection dans la page	Délimiteurs, message système prioritaire, aucun outil, contenu textuel borné, JSON strict.	● Conçu	Documenter un test adversarial dans le flux WF2 final.
Faux positif publié	Seuil haut, revue manuelle, fonction de retrait Owner et historique des events.	● Cycle prouvé	Formaliser la procédure de contestation avant usage réel.
Transaction dupliquée après timeout	Taxonomie d'erreurs, recheck on-chain obligatoire, trois tentatives maximum.	● Testé	Valider avec un RPC réel dégradé pendant le test E2E.
Double alerte concurrente	SQLite, révisions, CAS et claim unique avant Discord.	● Testé	Accepter l'état incertain si l'accusé Discord est ambigu.
Exposition de détails internes	Réponse WF4 filtrée, erreurs génériques, logs sans message RPC brut.	● Testé	Revalider après toute modification de schéma.

Durcissement des conteneurs



L'option no-new-privileges empêche l'élévation, un tmpfs borné reçoit les fichiers temporaires et le healthcheck n'expose aucune configuration. L'interface n8n est liée à 127.0.0.1 et utilise le compte propriétaire natif ainsi qu'une clé de chiffrement stable pour les credentials.

Audit du smart contract

Slither 0.11.5

- ✓ 0 alerte critique
- ✓ 0 alerte haute
- ✓ 0 alerte moyenne
- ✓ 0 alerte faible

Une information pragma seulement : OpenZeppelin ^0.8.20 et contrat ^0.8.24, compatibles avec le compilateur 0.8.24.

Revue manuelle

- ✓ Accès Owner/Reporter couvert par tests.
- ✓ Réentrance non applicable : aucun appel externe.
- ✓ Pas de boucle non bornée ni transfert de valeur.
- ✓ Front-running à impact limité : aucun fonds ni enchère.

Résidu principal. La sécurité des briques ne remplace pas celle du système intégré. Le rate limiting du futur webhook, le fetch SSRF-safe dans WF2, les credentials réels, les tests d'injection et l'exposition réseau de la démo doivent être validés ensemble avant toute ouverture au public.

17

Tests, couverture, CI et audit

Les chiffres ont été rejoués le 11 août 2026 sur main, commit 2e99059, avec Node 22.14.0.

118/118

tests Node passants

0 échec, 0 skip

13/13

tests Hardhat passants

100 %

statements, fonctions et

lignes Solidity

92,31 %

branches Solidity couvertes

Périmètre des 118 tests Node

Entrées et scripts

- Normalisation URL/wallet
- Catégories et scores
- Lecture et publication
- Réconciliation d'incertitude

Bridge HTTP

- Authentification
- Corps et schémas fermés
- Processus sans shell
- Taxonomie d'erreurs

Fiabilité WF3

- Décision et seuils
- Backoff et recheck
- Cycle SQLite
- Concurrence et ownership

Discord

- Défangeage
- Mentions neutralisées
- Claims gagnants
- Settlement ambigu

Exports n8n

- WF3/WF4 inactifs
- Aucun secret exporté
- Credentials référencés
- Wiring sécurisé

Persistence

- Redémarrage SQLite
- CAS canonique
- Détection de corruption
- Deux connexions concurrentes

Périmètre des 13 tests Hardhat

Domaine	Cas couverts
Administration	Owner initial, gestion réservée des reporters, adresse nulle refusée, révocation effective.
URLs	Stockage, événement, métadonnées, inconnue inactive, accès refusé, doublon, score, retrait et re-report.
Wallets	Stockage/lecture, wallet nul, score, doublon, retrait inactif et désactivation Owner.

Couverture du contrat

Fichier	Statements	Branches	Fonctions	Lignes
PhishingRegistry.sol	100 %	92,31 %	100 %	100 %

Intégration continue

Le pipeline GitHub Actions possède deux jobs. Le premier installe, compile, teste et mesure la couverture Hardhat. Le second valide la syntaxe JavaScript, exécute les tests Node et lance `npm audit --omit=dev`. Les dépendances sont installées avec `npm ci` sous Node 22.

Artefacts vérifiables

contracts/coverage.json
contracts/coverage/lcov.info
contracts/slither-report.json
ai/eval/report-v1.md
.github/workflows/ci.yml

Portée des preuves. Les 131 tests valident fortement le comportement local et hors ligne, mais ils ne remplacent pas un test live de WF1 → WF2 → WF3 → Polygon → Discord → WF4. Le rapport ne transforme donc pas la qualité unitaire en affirmation E2E.

18

Bilan par livrable

La valeur déjà produite est importante, mais la fin de projet dépend désormais de l'intégration et de la mesure.

Livrable	État	Réalisé	Reste à obtenir
L1 · Workflows n8n	● Partiel	Compose, bridge, WF3 et WF4 exportés/testés.	WF1/WF2, activation, credentials et chaînage complet.
L2 · Smart contract	● Réalisé	Contrat, tests, couverture, scripts, déploiement et vérification.	Uniquement maintenance si interface ou dépendances changent.
L3 · Module IA	● Partiel	Prompts, client, fallback, dataset, capture et rapport v1.	Recall v2 et atteinte de la cible $\geq 80\%$.
L4 · Audit sécurité	● Socle avancé	Slither, revue contrat, bridge et Docker durcis.	Tests intégrés SSRF/prompt injection/rate limit et revue E2E.
L5 · Rapport final	● En cours	Documentation technique abondante et présent rapport d'avancement.	Résultats E2E, latences, bilan final et soutenabilité mesurée.
L6 · Démo E2E	● À valider	Preuves isolées blockchain et tests hors ligne.	Scénario rejouable complet, Discord live et endpoint actif.

Difficultés rencontrées et réponses apportées

Difficulté	Observation	Réponse mise en œuvre	Suite
Contenu phishing éphémère	Nombreux domaines déjà morts ou refusés à la capture.	Priorité aux menaces actives, cache figé, index d'intégrité et historique séparé.	Capturer plus tôt et diversifier les sources récentes.
Pages courtes / SPA	Texte parfois absent sans signifier légitime.	Statuts empty/challenged et diagnostic v1 documenté.	Modes URL-only et structurel en v2.
Rappel IA faible	Sept FN issus du court-circuit, pas du sous-ensemble Gemini.	Cause racine tracée, métriques strictes conservées.	Implémenter les features URL et rejouer le même périmètre.
RPC et publication incertains	Un timeout ne révèle pas si la transaction a été minée.	Codes fermés, recheck systématique, backoff et retries bornés.	Injecter une panne RPC dans le test intégré.
Idempotence Discord	Pas de clé d'idempotence native.	Claim SQLite gagnant et fermeture incertain sans resend.	Prévoir une procédure d'audit manuel.
Secrets et commandes	n8n ne doit pas devenir une frontière de shell.	Bridge interne, token, spawn sans shell et séparation Owner/Reporter.	Valider la configuration locale avant activation.

Enseignements techniques

L'automatisation exige des états

Une suite de nodes ne suffit pas lorsqu'elle déclenche des transactions et alertes. Révisions, transitions canoniques et réconciliation rendent les reprises explicables.

La prudence peut réduire le rappel

Forcer la revue manuelle sur toute page courte protège contre les faux positifs, mais ignore des preuves URL utiles. Le bon compromis dépend du mode d'analyse.

L'immutabilité ne remplace pas la gouvernance

Un registre auditable doit aussi prévoir qui écrit, qui peut corriger, comment une contestation est traitée et quelles données sont publiées.

Une métrique doit rester honnête

Changer la définition de « positif » ou exclure les cas difficiles aurait amélioré artificiellement les chiffres sans améliorer le détecteur.

Position actuelle. Le projet n'est pas bloqué sur une inconnue générale. Les dépendances restantes sont précises : Recall v2, WF1, WF2, configuration locale, connexion des interfaces et validation E2E. Le socle blockchain/sécurité fournit déjà la destination et les garanties nécessaires à cette intégration.

19

Passer du socle à la démonstration

Une séquence courte et contrôlée permet de fermer les écarts sans remettre en cause l'architecture livrée.

Priorités ordonnées



P0 - Baseline et Recall v2

Figier commit, cache et paramètres du run v1 ; implémenter features URL, modes d'analyse, tests et rapport v2. Ne pas poursuivre si la précision descend sous 85 % ou le rappel reste sous 80 % sans analyse d'erreurs.



P1 - WF1 Ingestion

Ajouter webhook/formulaire, schéma strict, reportId, rate limiting, validation URL/wallet et déduplication via /internal/check.



P2 - WF2 Analyse

Intégrer le fetch SSRF-safe, les représentations bornées, le client IA v2, la conversion en risque, le score final et l'appel exact de WF3.



P3 - Activation contrôlée

Configurer les credentials chiffrés, tester les branches sans transaction, puis un cas .invalid malveillant sur Polygon Amoy et Discord.



P4 - Validation E2E et clôture

Rejouer doublon, panne RPC, prompt injection, SSRF, faux positif et check public ; mesurer latences, conserver tx hashes/captures et finaliser le rapport technique.

Scénario d'acceptation final



Critères de sortie techniques

- ✓ Précision IA $\geq 85\%$ et rappel $\geq 80\%$ sur le périmètre figé.
- ✓ Signalement → alerte en moins de 60 s, mesures horodatées.
- ✓ Un doublon ne produit ni seconde transaction ni seconde alerte finale.
- ✓ SSRF et prompt injection rejetés ou neutralisés par tests documentés.

Preuves à conserver

- ✓ Export des quatre workflows avec active documenté.
- ✓ Rapport IA v2 et paramètres complets du run.
- ✓ Tx hash PolygonScan, event, réponse WF4 et message Discord.
- ✓ Logs défangés, temps par étape, résultats de tests et audit final.

Conclusion

L'avancement démontre la faisabilité des parties structurantes : registre Web3 public et contrôlé, interaction sûre, action idempotente, IA structurée, dataset traçable et tests étendus. Le contrat est réellement déployé ; les comportements blockchain, de concurrence et d'erreur sont prouvés.

Les limites restent explicites : rappel IA insuffisant, WF1/WF2 non intégrés, WF3/WF4 inactifs et E2E non validé. La priorité est désormais de relier les briques, améliorer l'analyse du contenu pauvre et produire une preuve complète chronométrée.

Références de preuve dans le dépôt

README.md · PLAN.md	État global, architecture, réseau et plan initial.
contracts/contracts/PhishingRegistry.sol	Implémentation du registre et contrôle d'accès.
contracts/test/ · contracts/coverage/ · slither-report.json	Tests, couverture et audit.
ai/client/ · ai/prompts/ · ai/eval/report-v1.md	Client, prompts, schéma et résultats IA.
n8n/workflows/ · n8n/services/chain-bridge/	Exports WF3/WF4, bridge, persistance et coordination.

RAPPORT PRÉPARÉ COLLECTIVEMENT PAR

Lamkhaifi Mohamed · Malek Mouhcine